

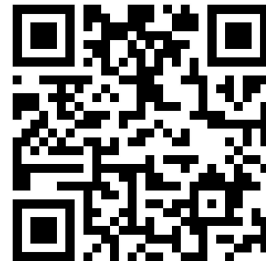
Securing OS with OpenSCAP and Ansible

ACM SIG Cyber



Rocky Linuxtm

Agenda



- Securing a system with cybersecurity compliance standards
- What does hardening a system get you
- Scanning a system for compliance
- Review compliance report
- Apply compliance settings using Ansible
- Scan and review compliance report after running ansible



Securing an OS

- Most OSes are not secure by default
- Helps reduce system vulnerabilities
- Consists of hundreds of configuration settings
- Security settings change over time



Security Compliance

- Compliance is about meeting security standards such as DISA STIGs
- Security standards are a set of best practices for cybersecurity controls
- Helps define processes and procedures that an organization can use to assess, monitor, and mitigate cybersecurity risk
- Important in highly regulated industries such as Energy, Healthcare, and Finance

Alternative compliance benchmark: Center for Internet Security (CIS) Critical Security Controls

DISA STIG is common in Department of Defense (DoD) environments

Importance of Security Compliance Controls

1 Cyber Defense

Security compliance controls are crucial for fortifying cyber defense against potential threats.

2 Regulatory Requirements

Compliance ensures adherence to regulatory standards and frameworks.

3 Risk Mitigation

Implementing security controls reduces the risk of security breaches and data loss.

What is a STIG?

- STIG stands for **S**ecurity **T**echnical **I**mplementation **G**uide
- It's a configuration standard consisting of cybersecurity requirements for a specific product such as operating system or browser
- STIG compliance levels
 - CAT 1 - Settings most at risk of serious exploitation
 - CAT2 - Vulnerabilities that have potential to result in a cybersecurity issue
 - CAT3 - Settings that lower the defenses if not applied

NOTE: STIG is a “guide” and not a requirement. You can chose not to implement a control

Red Hat Linux 9 STIG

Red Hat Enterprise Linux 9 Security Technical Implementation Guide

Overview

466 Security Controls

Version	Date	Finding Count (466)	Downloads
1	2023-09-13	CAT I (High): 21 CAT II (Med): 428 CAT III (Low): 17	Excel JSON XML

STIG Description

This Security Technical Implementation Guide is published as a tool to improve the security of Department of Defense (DOD) information systems. The requirements are derived from the National Institute of Standards and Technology (NIST) 800-53 and related documents. Comments or proposed revisions to this document should be sent via email to the following address: disa.stig_spt@mail.mil.

Available Profiles 

Source: https://www.stigviewer.com/stig/red_hat_enterprise_linux_9/

Windows 11 STIG

Microsoft Windows 11 Security Technical Implementation Guide

Overview

253 Security Controls

Version	Date	Finding Count (253)	Downloads
1	2022-06-24 	CAT I (High): 26CAT II (Med): 210CAT III (Low): 17	Excel  JSON  XML 

STIG Description

This Security Technical Implementation Guide is published as a tool to improve the security of Department of Defense (DoD) information systems. The requirements are derived from the National Institute of Standards and Technology (NIST) 800-53 and related documents. Comments or proposed revisions to this document should be sent via e-mail to the following address: disa.stig_spt@mail.mil.

Available Profiles 

Source: https://www.stigviewer.com/stig/microsoft_windows_11/2022-06-24/MAC-1_Sensitive/

A look at a STIG Rule

- Overview
 - Rule ID - Unique number for the specific rule
 - Severity - High, Medium, or Low
- Description
 - A description of the security control and the why
- Check Text
 - Commands used to verify the security control
- Configure Text
 - Commands used to implement the security control
 - *This section is used to create the ansible playbook*
 - **NOTE: Not all controls can be automated**
- Examples
 - [RHEL9 passwords must be created with a minimum of 15 characters](#)
 - [RHEL9 must have the firewalld package installed](#)

STIGs for other software

- Applications - Java, Apache web server, Microsoft Excel, Databases
- Cloud networks
- Mobile devices - Apple iOS, Android
- Operating systems - Linux, Windows
- Browsers - Firefox, Edge, Chrome
- Routers and servers
- Networks
- Network devices - Cisco VPNs

See <https://www.stigviewer.com/stigs>

OpenScap

What is OpenScap?

A tool that scans a system for security policies and compliance standards.



Why should you use OpenScap?

Automated Assessments

Automates security assessments based on STIG guidelines

Remediation Playbooks

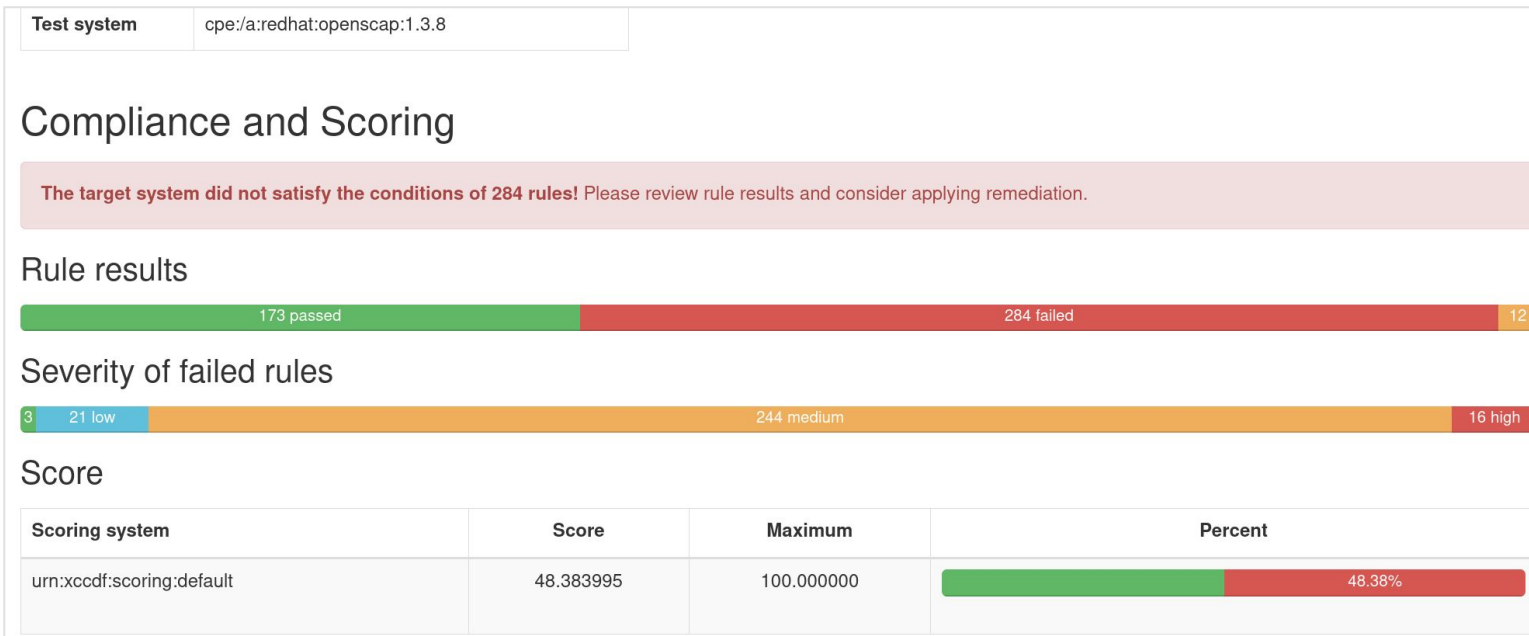
OpenScap generates Ansible playbooks for implementing STIG benchmarks.

Conservative Approach

OpenScap prioritizes system stability while implementing security controls

OpenSCAP Report

- Passed 173 rules
- Failed 284 rules
- Score: 48% :(



Ansible

A tool that automates the application of security benchmarks which are generated by OpenScap.



Automation benefits

Ansible automates the application of STIG benchmarks, ensuring consistency and accuracy

Customization

Ansible allows for customization of security controls based on specific system requirements

Efficiency and Scalability

Ansible streamlines the process of implementing STIG compliance across multiple systems.



Generates Playbooks



Ansible
Playbooks

- Ansible can be used on:
- Virtual Machines
 - Physical Servers
 - Cloud-based servers



AWS EC2



Azure VM



VMWare



Server



Laptop

OpenSCAP Report after Ansible

- Passed 374 rules
- Failed 84 rules
- Score: 67% :|

Compliance and Scoring

The target system did not satisfy the conditions of 84 rules! Please review rule results and consider applying remediation.

Rule results



Severity of failed rules



Score

Scoring system	Score	Maximum	Percent
urn:xccdf:scoring:default	67.853600	100.000000	67.85%

Preparing computer for demo

Install VMWare Fusion (Mac)

- <https://www.vmware.com/products/fusion/fusion-evaluation.html>

Create Virtual Machine - Rocky Linux

- <https://rockylinux.org/>

Install EPEL Repository setup

```
$ sudo dnf install epel-release
```

Install OpenScap

```
$ sudo dnf install openscap
```

Install STIG files

```
$ sudo dnf install scap-security-guide
```

Install Ansible

```
$ sudo dnf install ansible
```

Securing the OS

Run the initial OpenSCAP scan to generate report

```
$ oscap xccdf eval --profile xccdf_org.ssgproject.content_profile_stig \  
--results-arf rockylinux-result.xml \  
--report rockylinux-report.html \  
/usr/share/xml/scap/ssg/content/ssg-rhel9-ds.xml
```

Run Ansible to apply STIG security controls

```
$ ansible-playbook -i "localhost," -c local  
/usr/share/scap-security-guide/ansible/r19-playbook-stig_gui.yml
```

Re-Run the initial OpenSCAP scan to generate report

```
$ oscap xccdf eval --profile xccdf_org.ssgproject.content_profile_stig \  
--results-arf rockylinux-result-fixed.xml \  
--report rockylinux-report-fixed.html \  
/usr/share/xml/scap/ssg/content/ssg-rhel9-ds.xml
```